

## CR-001: Forgot Password and Password Reset Feature

### 1. Change Request Details

| Field             | Details                                                        |
|-------------------|----------------------------------------------------------------|
| Change Request ID | CR-001                                                         |
| Title             | Forgot Password and Password Reset Feature                     |
| Priority          | High                                                           |
| Difficulty        | Medium                                                         |
| Change Type       | Authentication / Security Enhancement                          |
| Affected Version  | Student Management System v1.0 baseline                        |
| Dependency        | Existing authentication/login system and user account database |

### 2. Business Requirement

Users who forget their password are currently unable to access their account unless the password is changed through an existing administrative or manual process.

The system should provide a secure and user-friendly **Forgot Password** facility that allows users to recover access to their account without requiring unnecessary administrator intervention.

The feature should allow a user to request a password reset using their registered email address and securely create a new password.

The password recovery process must protect user accounts from unauthorized password changes and must not weaken the existing authentication and authorization mechanisms.

### 3. Current Behaviour

- The Login page provides the existing username/email and password fields.
- Users can authenticate using their existing credentials.
- No Forgot Password option is currently available.
- Users who forget their password cannot initiate a password reset through the system.
- There is no dedicated password-reset request page.
- There is no dedicated password-reset process using a secure reset token.
- Existing authentication and authorization functionality is already implemented.

- Users must rely on an alternative/manual process if they forget their password.

#### 4. Requested Change

Add a **Forgot Password and Password Reset** facility to the Student Management System.

The implementation must:

- Provide a **Forgot Password** link on the Login page.
- Allow users to enter their registered email address.
- Validate the submitted email address.
- Process the password-reset request securely.
- Generate a secure password-reset token.
- Provide the user with a password-reset link or equivalent secure reset mechanism.
- Ensure reset tokens have a limited validity period.
- Reject expired or invalid reset tokens.
- Ensure a reset token cannot be reused after a successful password reset.
- Provide a password-reset page.
- Allow users to enter a new password.
- Allow users to confirm the new password.
- Validate the new password according to the existing password policy.
- Securely hash the new password before storing it.
- Display a clear success message after a successful password reset.
- Display an appropriate error message for invalid or expired reset requests.
- Preserve the existing Login functionality.
- Preserve existing administrator authentication and authorization.
- Avoid exposing unnecessary sensitive account information.
- Prevent unauthorized users from changing another user's password.

## **5. Scope**

### **In Scope**

- Forgot Password link on the Login page.
- Forgot Password request form.
- Email address validation.
- Password-reset request processing.
- Secure password-reset token generation.
- Password-reset token validation.
- Password-reset token expiration.
- Password-reset token one-time usage.
- Password reset form.
- New password validation.
- Password confirmation.
- Secure password hashing.
- Password reset success/error messages.
- Reset link or equivalent password recovery mechanism.
- Responsive Forgot Password interface.
- Preservation of existing authentication functionality.
- Security validation of the password-reset process.

### **Out of Scope**

- Complete redesign of the authentication system.
- Changes to user roles and permissions.
- Changes to administrator authorization.
- Social login.
- Two-factor authentication.
- Biometric authentication.

- Changes to unrelated Student Management System functionality.
- Changes to student CRUD functionality.
- Changes to student search/filter functionality.
- Unrelated database modifications.

## **6. Expected / Potentially Affected Files**

The following files may be affected depending on the existing project structure:

- frontend/src/pages/LoginPage.jsx
- frontend/src/pages/ForgotPasswordPage.jsx
- frontend/src/pages/ResetPasswordPage.jsx
- frontend/src/components/ForgotPasswordForm.jsx (optional)
- frontend/src/components/ResetPasswordForm.jsx (optional)
- Existing authentication stylesheet
- Existing routing configuration
- Existing authentication service/API file
- Existing backend authentication controller
- Existing authentication routes
- Existing user model
- Password-reset service or utility (if required)

Students may modify additional files if required.

Any additional files must be identified and justified in the Implementation Report.

## **7. Functional & Security Requirements**

### **Functional Requirements**

#### **FR-001**

A Forgot Password option shall be available on the Login page.

#### **FR-002**

The user shall be able to enter their registered email address.

#### **FR-003**

The system shall process a password-reset request.

#### **FR-004**

The system shall generate a secure password-reset token or equivalent secure reset mechanism.

#### **FR-005**

The system shall provide a password-reset mechanism to the user.

#### **FR-006**

The password-reset token shall have a limited validity period.

#### **FR-007**

The system shall reject invalid, expired, or already-used reset tokens.

#### **FR-008**

The user shall be able to enter a new password.

#### **FR-009**

The user shall be able to confirm the new password.

#### **FR-010**

The system shall validate the new password according to the defined password policy.

#### **FR-011**

The system shall securely store the new password after successful validation.

#### **FR-012**

The system shall display a successful password-reset message after the password has been changed.

#### **FR-013**

The system shall display a clear error message when the password-reset request is invalid or expired.

#### **FR-014**

The user shall be able to log in using the newly created password.

#### **FR-015**

Existing login functionality shall continue to operate after implementation.

### **Security Requirements**

#### **SEC-001**

Existing user authentication and administrator authorization shall remain unchanged.

#### **SEC-002**

Passwords shall never be stored in plain text.

#### **SEC-003**

New passwords shall be securely hashed before being stored.

#### **SEC-004**

Password-reset tokens shall be generated using a secure random mechanism.

#### **SEC-005**

Password-reset tokens shall expire after a defined period.

#### **SEC-006**

A successfully used password-reset token shall not be reusable.

#### **SEC-007**

The password-reset process shall not allow an unauthorized user to change another user's password.

#### **SEC-008**

The system shall avoid unnecessarily revealing whether a specific email address is registered.

## **SEC-009**

The feature shall not expose passwords, reset tokens, or other sensitive information unnecessarily through error messages or logs.

## **SEC-010**

The implementation shall not use unsafe HTML rendering for user-controlled information.

## **8. Acceptance Criteria**

The CR is successfully implemented when:

- **AC-001:** Users can access the Forgot Password feature from the Login page.
- **AC-002:** Users can submit their email address to request a password reset.
- **AC-003:** The system provides a secure password-reset mechanism.
- **AC-004:** Password-reset tokens expire after the configured validity period.
- **AC-005:** Invalid and expired password-reset tokens are rejected.
- **AC-006:** Users can enter and confirm a new password.
- **AC-007:** Password validation is correctly applied.
- **AC-008:** The new password is securely hashed before storage.
- **AC-009:** Users can log in using the newly created password.
- **AC-010:** A password-reset token cannot be reused after successful password reset.
- **AC-011:** The system does not unnecessarily expose whether an email address belongs to a registered account.
- **AC-012:** Existing login functionality continues to work.
- **AC-013:** Existing administrator authentication and authorization continue to work.
- **AC-014:** Existing Student Management System CRUD functionality continues to work correctly.

## 9. Expected Outcome

Users can securely recover access to their accounts when they forget their password without requiring unnecessary administrator intervention.

The new Forgot Password feature provides a secure password-reset workflow while ensuring that:

- Existing authentication remains functional.
- Existing authorization remains unchanged.
- User passwords remain securely hashed.
- Reset tokens are temporary and protected against reuse.
- Invalid reset requests are rejected.
- Existing Student Management System CRUD functionality remains unchanged.

## 10. Implementation Report Requirement

After implementation, the **Final Exam Software Change Implementation Report** shall include:

- Implementation summary.
- Affected files.
- Important technical/security changes.
- Password-reset workflow description.
- Test cases and results.
- Acceptance criteria verification.
- Relevant screenshots/evidence.
- Final status.
- Outstanding issues.

## Test Cases

| Test ID | Test Case                         | Expected Result                           |
|---------|-----------------------------------|-------------------------------------------|
| TC-001  | Click Forgot Password             | Forgot Password page opens                |
| TC-002  | Enter valid email                 | Reset request is processed                |
| TC-003  | Enter invalid email format        | Validation message appears                |
| TC-004  | Enter unknown email               | Appropriate generic response appears      |
| TC-005  | Open valid reset link             | Password Reset page opens                 |
| TC-006  | Open expired reset link           | Reset request is rejected                 |
| TC-007  | Use invalid reset token           | Reset request is rejected                 |
| TC-008  | Enter mismatched passwords        | Validation error appears                  |
| TC-009  | Enter weak password               | Password validation error appears         |
| TC-010  | Enter valid new password          | Password is successfully changed          |
| TC-011  | Login with new password           | Login succeeds                            |
| TC-012  | Login with old password           | Old password is rejected                  |
| TC-013  | Reuse reset token                 | Token is rejected                         |
| TC-014  | Check password storage            | Password is securely hashed               |
| TC-015  | Test existing administrator login | Administrator can still authenticate      |
| TC-016  | Test existing CRUD functions      | Existing CRUD operations continue to work |

## Final Status

**Change Request:** CR-002

**Feature:** Forgot Password and Password Reset

**Priority:** High

**Implementation Status:** To Be Completed / Completed

**Testing Status:** To Be Completed / Completed

**Acceptance Criteria:** Pending Verification / Passed

**Final Status:** Pending Review / Completed

## Outstanding Issues

If no issues remain after implementation:

**None identified.**

If issues remain, they should be documented with:

| Issue ID  | Description                      | Severity        | Status |
|-----------|----------------------------------|-----------------|--------|
| ISSUE-001 | Description of outstanding issue | High/Medium/Low | Open   |